

ENTERPRISE CYBERSECURITY & ACCESS GOVERNANCE POLICY

1. PURPOSE & SCOPE

This policy defines mandatory security requirements for corporate network access, data handling, and remote device management across all internal departments and third-party contractors.

2. MANDATORY REQUIREMENTS & AUTHENTICATION

- Multi-Factor Authentication (MFA) is strictly mandatory for all employees and system administrators.
- Acceptable MFA methods include hardware security keys (FIDO2) and authenticator apps (TOTP).
- SMS-based OTP verification is prohibited for administrative roles due to SIM-swapping vulnerabilities.
- Passwords must be at least 16 characters in length and updated every 90 days.

3. SECURE REMOTE ACCESS & ENCRYPTION

- All remote connections must traverse the corporate encrypted VPN tunnel with TLS 1.3 enabled.
- Unmanaged personal devices (BYOD) are strictly forbidden from directly connecting to production servers.
- Confidential data stored on laptops or portable drives must use AES-256 full-disk encryption.

4. INCIDENT REPORTING & COMPLIANCE ACTIONS

- Any suspected credential compromise or phishing attempt must be reported to SOC within 15 minutes.
- Employees must complete mandatory bi-annual security awareness and phishing simulations.
- Failure to adhere to this policy will result in immediate revocation of access privileges.